Ecole Supérieure d'Informatique et du Numérique
COLLEGE OF ENGINEERING & ARCHITECTURE

ETHICAL HACKING & DEFENSE

C|EH Certified Ethical Hacker

PRÉPARÉ PAR:
SEBBAR ANASS

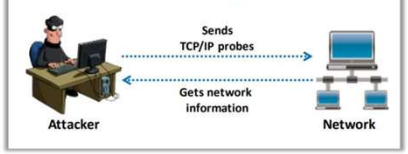
EC-COUNCIL | ACADEMIA PARTNER

Année universitaire: 2026-2027

1

Overview of Network Scanning

- Network scanning refers to a set of procedures used for **identifying hosts, ports,** and **services** in a network
- Network scanning is one of the **components of intelligence gathering** which can be used by an attacker to create a profile of the target organization



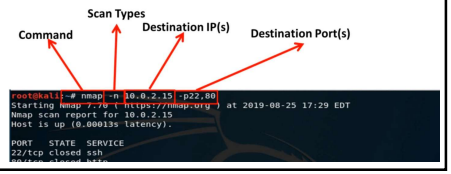
Objectives of Network Scanning

- To discover live hosts, IP address, and open ports of live hosts
- To discover operating systems and system architecture
- To discover services running on hosts
- To discover vulnerabilities in live hosts

2

Attaques visant la collecte d'information

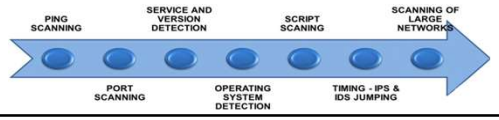
- Attaques par balayage de ports
  - Balayage TCP (SYN, ACK, FIN, Xmas, Null)
  - Balayage UDP
- Attaques permettant de prendre l'empreinte du système d'exploitation(OS Fingerprinting)
  - Empreinte TCP
  - Empreinte ICMP
- Scan de vulnérabilités



3

Attaques par balayage de ports

- L'objectif du balayage est de savoir si un logiciel est en écoute sur un numéro de port donné. Si un logiciel écoute, on dit que le port est *ouvert*, sinon on dit qu'il est *fermé*.
- Le balayage d'un port se passe en deux étapes :
  - l'envoi d'un paquet sur le port testé ;
  - l'analyse de la réponse.
- NMAP: Logiciel de balayage (ou de scan) de ports, très répondu, connu pour son efficacité
  - Nmap a une granularité bien plus fine. Il divise les ports selon six états: **ouvert (open), fermé (closed), filtré (filtered), non-filtré (unfiltered), ouvert|filtré (open|filtered), et fermé|filtré (closed|filtered).**



4

Les techniques de scan de Nmap

Nmap Scan	Command Syntax	Requires Privileged Access	Identifies TCP Ports	Identifies UDP Ports
TCP SYN Scan	-sS	YES	YES	NO
TCP connect() Scan	-sT	NO	YES	NO
FIN Scan	-sF	YES	YES	NO
Xmas Tree Scan	-sX	YES	YES	NO
Null Scan	-sN	YES	YES	NO
Ping Scan	-sP	NO	NO	NO
Version Detection	-sV	NO	NO	NO
UDP Scan	-sU	YES	NO	YES
IP Protocol Scan	-sO	YES	NO	NO
ACK Scan	-sA	YES	YES	NO
Window Scan	-sW	YES	YES	NO
RPC Scan	-sR	NO	NO	NO
List Scan	-sL	NO	NO	NO
Idlescan	-sI	YES	YES	NO
FTP Bounce Attack	-b	NO	YES	NO

5

Les états des ports détectés par nmap

- Nmap est scanneur de ports efficace, il divise les ports selon six états :
  - **Ouvert (open)** : une application accepte des connexions TCP ou des paquets UDP sur ce port. Trouver de tels ports est souvent le but principal du scan de port. Ils se sont considérés comme des boulevards pour une attaque.
  - **Fermé (closed)** : un port fermé est accessible, donc il peut être intéressant de le scanner de nouveau plus tard au cas où il s'ouvrirait.
  - **Filtré (filtred)** : nmap ne peut pas toujours déterminer si un port est ouvert car les dispositifs de filtrage des paquets empêchent les paquets de test d'atteindre leur port cible. Le dispositif de filtrage peut être un pare-feu dédié, des règles de routeurs filtrants ou un pare-feu logiciel.

6

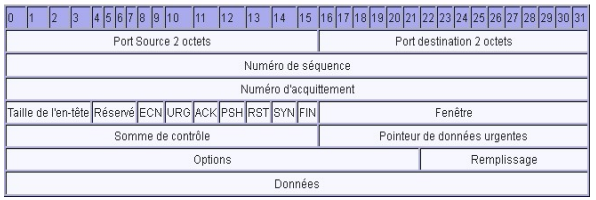
Les états des ports détectés par nmap

- Les trois autres états de ports :
  - **Non-filtré (unfiltred) :** L'état non-filtré signifie qu'un port est accessible, mais que Nmap est incapable de déterminer s'il est ouvert ou fermé.
  - **Ouvert-filtré (open-filtred) :** Nmap met dans cet état les ports dont il est incapable de déterminer l'état entre ouvert et filtré. Ceci arrive pour les types de scans où les ports ouverts ne renvoient pas de réponse.
  - **Fermé-filtré (closed-filtred) :** Cet état est utilisé quand Nmap est incapable de déterminer si un port est fermé ou filtré. Cet état est seulement utilisé par le scan Idle basé sur les identifiants de paquets IP.

7

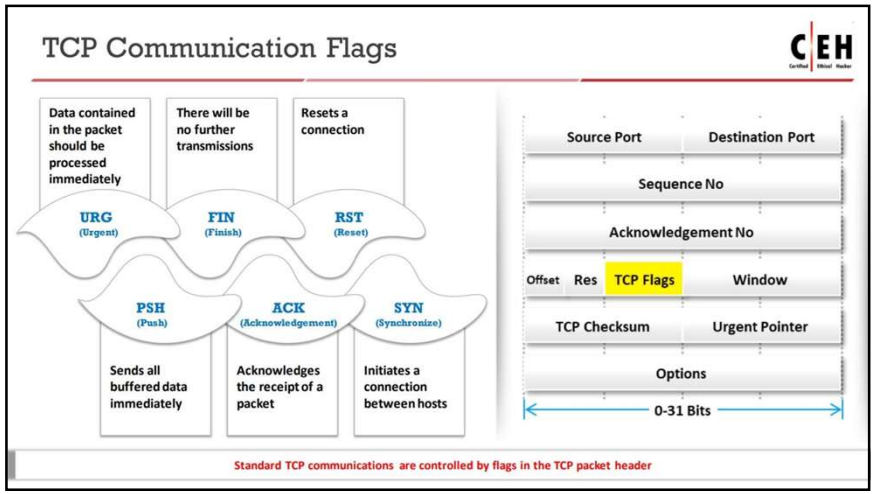
Structure d'un segment TCP

En bits

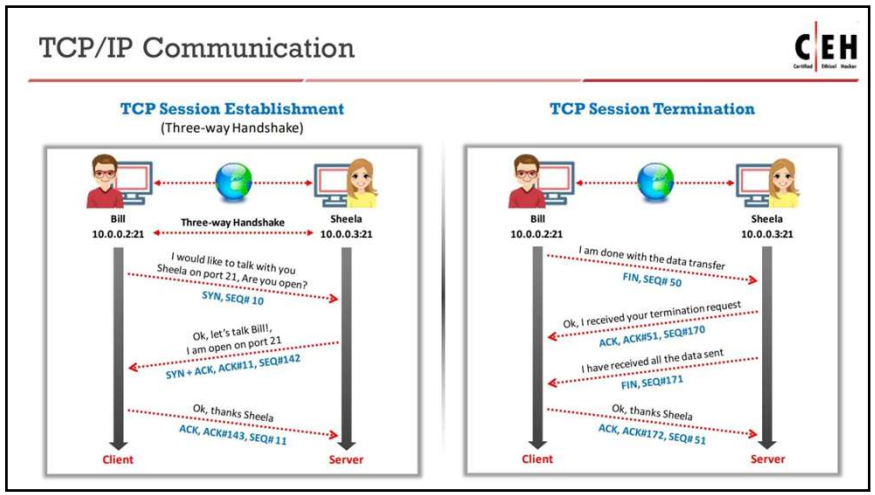


- Drapeaux
  - **Réservé** : réservé pour un usage futur
  - **ECN** : signale la présence de congestion, voir RFC 3168
  - **URG** : Signale la présence de données **urg**entes
  - **ACK** : signale que le paquet est un accusé de réception (**ack**nowledgement)
  - **PSH** : données délivrées immédiatement à l'application sans attendre que le tampon du récepteur soit plein (**push**)
  - **RST** : rupture anormale de la connexion (**reset**) (réinitialisation de la connexion)
  - **SYN** : demande de synchronisation (SYN) ou établissement de connexion
  - **FIN** : demande la FIN de la connexion

8



9



10

Attaques par balayage TCP

- Il existe de nombreuses variantes pour le paquet émis. Il y a le paquet valide selon la norme TCP, **le paquet « TCP SYN »**, et les paquets invalides.
- L'utilisation des paquets invalides vise à tromper les systèmes de détection d'intrusion. La liste des **paquets invalides** utilisés est :
  - ACK ;
  - Maimon (FIN/ACK) ;
  - Xmas (tous) ;
  - FIN ;
  - NULL (aucun) ;
  - *Window* (ACK).
- Le serveur peut répondre de différentes manières :
  - ouverture de connexion acceptée : envoi d'un paquet TCP SYN/ACK ;
  - fermeture de la connexion : envoi d'un paquet TCP RST ;
  - absence de réponse : on dit que le paquet est *droppé*.

11

Structure d'un segment TCP

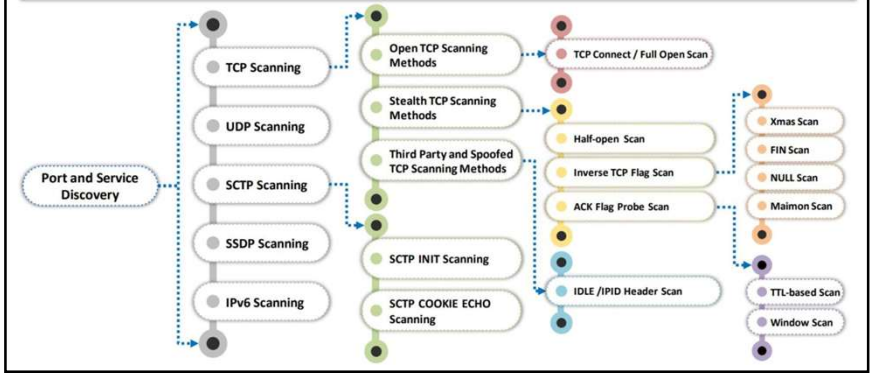
Signification des champs :

- **Port source** : numéro du port source
- **Port destination** : numéro du port destination
- **Taille de l'en-tête** : longueur de l'en-tête en mots de 32 bits (les options font partie de l'en-tête)
- **Fenêtre** : taille de fenêtre demandée, c'est-à-dire le nombre d'octets que le récepteur souhaite recevoir sans accusé de réception
- **Somme de contrôle** : somme de contrôle calculée sur l'ensemble de l'en-tête TCP et des données
- **Pointeur de données urgentes** : position relative des dernières données urgentes
- **Options** : (de taille variable selon les options ajoutées. Ex. : MSS – Maximum Segment Size, Timestamp pour calculer RTT).
- **Remplissage** : zéros ajoutés pour aligner les champs suivants du paquet sur 32 bits, si nécessaire
- **Données** : séquences d'octets transmis par l'application (par exemple : +OK POP3 server ready...)

12

Port Scanning Techniques

The port scanning techniques are **categorized according to the type of protocol** used for communication



13

Port Scanning Techniques (Cont'd)

Scanning Technique	Nmap Command	Request	Response	Advantages	Disadvantages
TCP Connect/Full-Open Scan	nmap –sT –v <Target IP Address>	SYN packets	✓ SYN+ACK packet response - Port is open ✓ RST packet response - Port is closed	✓ Does not require super-user privileges	✓ Easily detectable and filterable ✓ The logs in the target system disclose the connection
Stealth Scan (Half-Open Scan)	nmap –sS –v <Target IP Address>	Single SYN packet	✓ SYN+ACK packet response - Port is open ✓ RST packet response - Port is closed	✓ Bypasses firewall rules and logging mechanisms	
Inverse TCP Flag Scan	nmap –(-sF, -sN, -sX) –v <Target IP Address>	Probe packet (FIN/URG/PSH/NULL)	✓ No response - Port is open ✓ RST packet response - Port is closed	✓ Avoids many IDS and logging systems; highly stealthy	✓ Requires raw access to network sockets and super-user privileges ✓ Not effective against Microsoft Windows hosts, in particular
Xmas Scan	nmap –sX –v <Target IP Address>	Probe packet (FIN + URG + PSH)	✓ No response - Port is open ✓ RST packet response - Port is closed	✓ Avoids IDS and the TCP three-way handshake	✓ Works only when systems are compliant with the RFC 793–based TCP/IP implementation ✓ Works on the Unix platform only ✓ Does not work against any current version of Microsoft Windows

14

Port Scanning Techniques (Cont'd)

Scanning Technique	Nmap Command	Request	Response	Advantages	Disadvantages
FIN Scan	nmap –sF –v <Target IP Address>	Probe packet (FIN)	✓ No response - Port is open ✓ RST packet response - Port is closed	✓ Probe packets enabled with TCP flags can pass through filters undetected, depending on the security mechanisms installed ✓ Works only when systems are compliant with the RFC 793–based TCP/IP implementation	✓ Effective only when used with Unix-based OSes ✓ Does not work against any current version of Microsoft Windows
NULL Scan	nmap –sN –v <Target IP Address>	Probe packet (NULL)	✓ No response - Port is open ✓ RST packet response - Port is closed		
TCP Maimon Scan	nmap –sM –v <Target IP Address>	Probe packet (FIN/ACK)	✓ No response - Port is open ✓ ICMP unreachable error response - Port is filtered ✓ RST packet response - Port is closed		

15

Port Scanning Techniques (Cont'd)

Scanning Technique	Nmap Command	Request	Response	Advantages	Disadvantages
ACK Flag Probe Scan	nmap –sA –v <Target IP Address>	ACK probe packets	✓ No response - Port is filtered (stateful firewall is present) ✓ RST packet response - Port is not filtered (no firewall is present)	✓ Can evade IDS in most cases ✓ Helps in checking the filtering systems of target networks	✓ Extremely slow and can exploit only older OSes with vulnerable BSD-derived TCP/IP stacks
TTL-Based ACK Flag Probe Scan	nmap –sA –ttl 100 –v <target IP address>	ACK probe packets (several thousands) to different TCP ports	✓ RST packet response - Port is open (TTL value on a port < 64) ✓ RST packet response - Port is closed (TTL value on a port > 64)		
Window-Based ACK Flag Probe Scan	nmap –sA –sW –v <target IP address>	ACK probe packets (several thousands) to different TCP ports	✓ RST packet response - Port is open (WINDOW value on a port is non-zero) ✓ ICMP unreachable error response - Port is filtered ✓ RST packet response - Port is closed (WINDOW value on a port is zero)		
IDLE/IPID Header Scan	nmap –Pn –p– –sI <Zombie Hostname> <Target Hostname>	SYN packet	✓ SYN+ACK packet response - Port is open ✓ RST packet response - Port is closed	✓ Offers the complete blind scanning of a remote host	✓ Requires the identification of sequence numbers of the zombie host

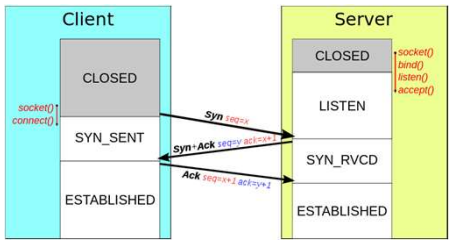
16

Port Scanning Techniques (Cont'd)

Scanning Technique	Nmap Command	Request	Response	Advantages	Disadvantages
UDP Scan	nmap –sU –v <Target IP Address>	UDP packet	✓ No response - Port is open ✓ ICMP unreachable error response - Port is closed	✓ Less informal with regard to an open port because there is no overhead of a TCP handshake ✓ Microsoft-based OSes do not usually implement any ICMP rate limiting; hence, this scan operates very efficiently on Windows-based devices	✓ Slow because it limits the ICMP error message rate as a form of compensation to machines that apply RFC 1812 section 4.3.2.8 ✓ A remote host will require access to the raw ICMP socket to distinguish closed ports from unreachable ports ✓ Requires privileged access
SCTP INIT Scan	nmap –sY –v <Target IP Address>	INIT chunk	✓ INIT+ACK chunk - Port is open ✓ ICMP unreachable exception - Port is filtered ✓ ABORT chunk - Port is closed	✓ An INIT scan is performed quickly by scanning thousands of ports per second on a fast network not obstructed by a firewall, offering a strong sense of security ✓ Can clearly differentiate between various ports such as open, closed, and filtered states	
SCTP COOKIE ECHO Scan	nmap –sZ –v <Target IP Address>	COOKIE ECHO chunk	✓ No response - Port is open ✓ ABORT chunk - Port is closed	✓ The COOKIE ECHO chunk is not blocked by non-stateful firewall rule sets. ✓ Only an advanced IDS can detect an SCTP COOKIE ECHO scan	✓ Cannot differentiate clearly between open and filtered ports, showing the output as open|filtered in both cases

17

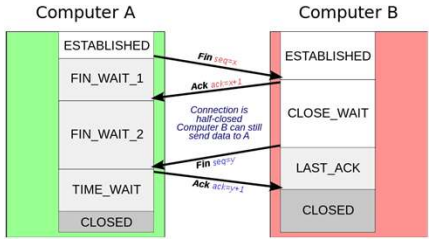
Établissement d'une connexion TCP



- Le côté *client* de la connexion effectue une *ouverture active* en 3 temps :
  - Le client envoie un segment SYN au serveur,
  - Le serveur lui répond par un segment SYN/ACK,
  - Le client confirme par un segment ACK.

18

Terminaison d'une connexion TCP



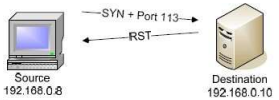
- La phase de terminaison d'une connexion utilise **un handshaking en quatre temps**, chaque extrémité de la connexion effectuant sa terminaison de manière indépendante.
- La fin d'une connexion nécessite **une paire de segments FIN et ACK** pour chaque extrémité.

19

Attaque par balayage SYN

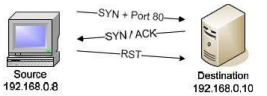
TCP SYN Scan (nmap –sS @IP)

- Si **le port est fermé**, il répond par un **RST**




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8]   [192.168.0.10]  TCP: D=113 S=57283 SYN SEQ=2360927338 LEN=0 WIN=3072
[192.168.0.10]  [192.168.0.8]   TCP: D=57283 S=113 RST ACK=2360927339 WIN=0
```

- Si **le port est ouvert**, il répond par un **SYN/ACK**




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8]   [192.168.0.10]  TCP: D=80 S=57283 SYN SEQ=2360927338 LEN=0 WIN=3072
[192.168.0.10]  [192.168.0.8]   TCP: D=57283 S=80 SYN ACK=2360927339 SEQ=1622899389 LEN=0 WIN=65535
[192.168.0.8]   [192.168.0.10]  TCP: D=80 S=57283 RST WIN=0
```

20

Attaque par balayage SYN

TCP SYN Scan (nmap –sS @IP)

- **Avantage** du TCP SYN Scan
  - Le balayage TCP SYN **ne crée jamais de session TCP**. De ce fait, **il n'est pas journalisé** par les applications de l'ordinateur de destination.
  - Ce balayage est plus discret que le balayage TCP connect().
  - Puisqu'aucune session d'application n'a été ouverte, le balayage SYN scan n'a aucun impact réel sur les performances de l'application.
- **Inconvénient** du TCP SYN Scan
  - Le balayage TCP SYN **nécessite un accès privilégié** au système (accès avec compte administrateur). Sans un accès privilégié, nmap ne peut pas créer des paquets raw nécessaires pour accomplir des balayages se basant sur un processus de connexion semi-ouverte (half-open connection process).

17

21

Nmap output

```
# nmap -sS -v 192.168.0.10

Starting nmap 3.81 ( http://www.insecure.org/nmap/ ) at 2005-04-11 12:25 EDT
Initiating SYN Stealth Scan against 192.168.0.10 [1663 ports] at 12:25
Discovered open port 80/tcp on 192.168.0.10
Discovered open port 3389/tcp on 192.168.0.10
Discovered open port 3306/tcp on 192.168.0.10
Discovered open port 139/tcp on 192.168.0.10
Discovered open port 135/tcp on 192.168.0.10
Discovered open port 520/tcp on 192.168.0.10
Discovered open port 445/tcp on 192.168.0.10
The SYN Stealth Scan took 1.35s to scan 1663 total ports.
Host 192.168.0.10 appears to be up ... good.
Interesting ports on 192.168.0.10:
(The 1656 ports scanned but not shown below are in state: closed)
PORT     STATE SERVICE
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
520/tcp  open  efs
3306/tcp open  mysql
3389/tcp open  ms-term-serv
MAC Address: 00:30:48:11:AB:5A (Supermicro Computer)

Nmap finished: 1 IP address (1 host up) scanned in 2.117 seconds
               Raw packets sent: 1705 (68.2KB) | Rcvd: 1664 (76.5KB)
#
```

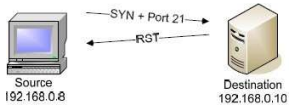
18

22

Attaque par balayage TCP connect()

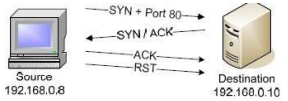
TCP connect() Scan (nmap –sT @IP)

- Si **le port est fermé**, il répond par un **RST**




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8]   [192.168.0.10] TCP: D=21 S=41441 SYN SEQ=33655397736 LEN=0 WIN=5840
[192.168.0.10]  [192.168.0.8]  TCP: D=41441 S=21 RST ACK=33655397737 WIN=0
```

- Si **le port est ouvert**, le scan TCP connect(), complète le **TCP three-way handshake**, puis envoie un **RST** pour fermer la connexion.




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8]   [192.168.0.10]  TCP: D=80 S=49389 SYN SEQ=3362197786 LEN=0 WIN=5840
[192.168.0.10]  [192.168.0.8]   TCP: D=49389 S=80 SYN ACK=3362197787 SEQ=58695210 LEN=0 WIN=65535
[192.168.0.8]   [192.168.0.10]  TCP: D=80 S=49389 ACK=58695211 WIN<-2=5840
[192.168.0.8]   [192.168.0.10]  TCP: D=80 S=49389 RST ACK=58695211 WIN<<2=5840
```

23

Attaque par balayage TCP connect()

TCP connect() Scan (nmap –sT @IP)

```
└─$ sudo nmap -vv -sT 45.33.32.156
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-30 03:39 EDT
Initiating Ping Scan at 03:39
Scanning 45.33.32.156 [4 ports]
Completed Ping Scan at 03:39, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 03:39
Completed Parallel DNS resolution of 1 host. at 03:39, 0.00s elapsed
Initiating Connect Scan at 03:39
Scanning scanme.nmap.org (45.33.32.156) [1000 ports]
Discovered open port 80/tcp on 45.33.32.156
Discovered open port 22/tcp on 45.33.32.156
Discovered open port 5060/tcp on 45.33.32.156
Discovered open port 9929/tcp on 45.33.32.156
Discovered open port 31337/tcp on 45.33.32.156
Completed Connect Scan at 03:39, 22.17s elapsed (1000 total ports)
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up, received reset ttl 128 (0.13s latency).
Scanned at 2024-10-30 03:39:29 EDT for 22s
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE    REASON
22/tcp    open  ssh        syn-ack
80/tcp    open  http       syn-ack
5060/tcp  open  sip        syn-ack
9929/tcp  open  nping-echo syn-ack
31337/tcp open  Elite      syn-ack

Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 22.31 seconds
           Raw packets sent: 4 (152B) | Rcvd: 1 (40B)
```

Avantages :

- **Fiabilité** : Comme la connexion TCP est complètement établie, les résultats sont fiables et précis pour identifier les ports ouverts.
- **Compatibilité** : Utilise la fonction système connect(), qui est disponible sur tous les systèmes et ne nécessite pas de privilèges élevés.

Inconvénients :

- **Détectabilité** : Le scan connect() est facilement détecté par les systèmes IDS (Intrusion Detection Systems), car il établit une connexion complète. Les connexions répétées sur différents ports peuvent déclencher des alertes.
- **Lenteur** : En raison du handshake complet pour chaque port, ce scan est plus lent que d'autres méthodes de scan, comme le scan SYN.

24

Attaque par balayage ACK

ACK Scan (-sA)

- Ce type de scan est différent des autres car il ne peut pas déterminer si un port est ouvert (ni même ouvert|filtré).
- Il est **utilisé pour découvrir les règles des pare-feux,** déterminant s'ils sont **avec ou sans états** (statefull/stateless) et quels ports sont filtrés.
- Le scan ACK n'active, en général, que le drapeau ACK des paquets.
  - Les systèmes non-filtrés réagissent en retournant un paquet RST. Nmap considère alors le port comme non-filtré, signifiant qu'il est accessible avec un paquet ACK, mais sans savoir s'il est réellement ouvert ou fermé.
  - Les ports qui ne répondent pas ou renvoient certains messages d'erreur ICMP (type 3, code 1, 2, 3, 9, 10, ou 13), sont considérés comme filtrés.

25

Attaque par balayage ACK

ACK Scan (-sA)

Messages de contrôle du protocole ICMP

Type	Code	Description
0 – Echo Reply	0	Echo reply (used to ping)
3 – Destination Unreachable	0	Destination network unreachable
	1	Destination host unreachable
	2	Destination protocol unreachable
	3	Destination port unreachable
	4	Fragmentation required, and DF flag set
	5	Source route failed
	6	Destination network unknown
	7	Destination host unknown
	8	Source host isolated
	9	Network administratively prohibited
	10	Host administratively prohibited
	11	Network unreachable for TOS
	12	Host unreachable for TOS
	13	Communication administratively prohibited
	14	Host Precedence Violation
	15	Precedence cutoff in effect

26

Attaque par balayage ACK

ACK Scan (-sA)

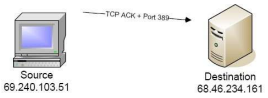
Messages de contrôle du protocole ICMP

- **Echo Request et Echo Reply (Types 8 et 0)**
  - Echo Request (**Type 8**) : Envoyé par l'hôte source pour demander une réponse de l'hôte de destination.Echo
  - Reply (**Type 0**) : Réponse envoyée par l'hôte de destination, indiquant qu'il est joignable.
- **Destination Unreachable (Type 3)**
  - **Code 0** : Réseau inaccessible.
  - **Code 1** : Hôte inaccessible.
  - **Code 3** : Port inaccessible (généralement lorsque le port est fermé).
  - **Code 13** : Communication administrativement interdite (par exemple, bloquée par un pare-feu).
- **Redirect (Type 5)**
  - Le routeur envoie un message ICMP Redirect pour informer l'émetteur de mettre à jour sa table de routage avec une meilleure route.
- **Time Exceeded (Type 11)**
  - **Code 0** : TTL expiré en transit. Utilisé par l'outil traceroute pour identifier chaque routeur sur le chemin vers une destination.
  - **Code 1** : Fragmentation requise mais non autorisée.
- **Router Advertisement et Router Solicitation (Types 9 et 10)**
  - Router Solicitation (**Type 10**) : Envoyé par un hôte pour découvrir les routeurs disponibles sur le réseau.
  - Router Advertisement (**Type 9**) : Réponse des routeurs à la demande, fournissant des informations sur les routeurs disponibles.
- **Timestamp Request et Timestamp Reply (Types 13 et 14)**
- **Address Mask Request et Address Mask Reply (Types 17 et 18)**

27

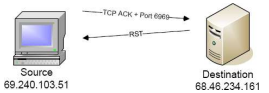
Attaque par balayage ACK

- Si **le port est filtré**, il n'y a pas de réponse ou réception d'un message **ICMP destination unreachable**




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[69.240.103.51] [68.46.234.161] TCP: D=389 S=38667      ACK=0 WIN=3072
```

- Si **le port est unfiltred**, il répond par un **RST**




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[69.240.103.51] [68.46.234.161] TCP: D=6969 S=38667     ACK=0 WIN=1024
[68.46.234.161] [69.240.103.51] TCP: D=38667 S=6969 RST WIN=0
```

23

28

Attaque par balayage ACK

```
└─$ sudo nmap -v -sA 45.33.32.156 -Pn
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-30 03:36 EDT
Initiating Parallel DNS resolution of 1 host. at 03:36
Completed Parallel DNS resolution of 1 host. at 03:36, 0.04s elapsed
Initiating ACK Scan at 03:36
Scanning scanme.nmap.org (45.33.32.156) [1000 ports]
Completed ACK Scan at 03:36, 0.14s elapsed (1000 total ports)
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.00028s latency).
All 1000 scanned ports on scanme.nmap.org (45.33.32.156) are in ignored states.
Not shown: 1000 unfiltered tcp ports (reset)

Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds
           Raw packets sent: 1000 (40.000KB) | Rcvd: 1000 (40.000KB)
```

24

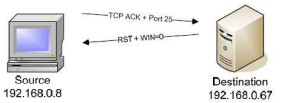
29

Attaque par balayage ACK

avec vérification de la taille de la fenêtre TCP

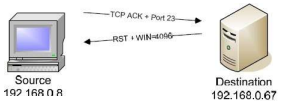
Window Scan (-sW)

- Une réponse **RST** reçue d'un port fermé, a **une taille nulle de la fenêtre (window size).**



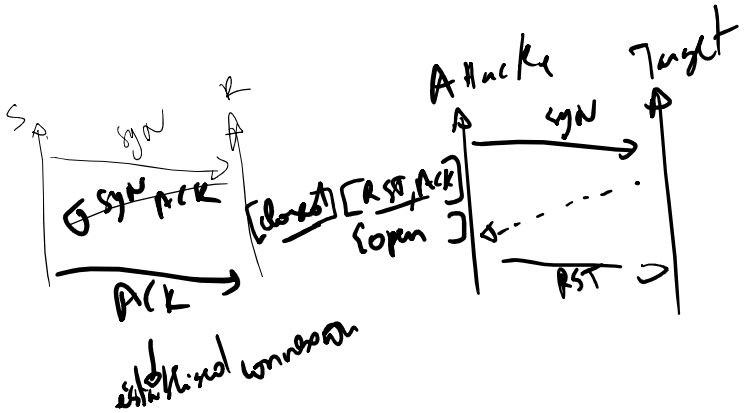

```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8]   [192.168.0.67] TCP: D=25 S=62405      ACK=0 WIN=2048
[192.168.0.67] [192.168.0.8]   TCP: D=62405 S=25 RST WIN=0
```

- Quand un port ouvert reçoit un TCP ACK, la station de destination répond avec un **RST**, mais **la taille de la fenêtre n'est pas nulle**.




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8]   [192.168.0.67] TCP: D=23 S=62405      ACK=0 WIN=3072
[192.168.0.67] [192.168.0.8]   TCP: D=62405 S=23 RST WIN=4096
```

30



31

Attaque par balayage ACK

avec vérification de la taille de la fenêtre TCP

Window Scan (-sW)

```
# nmap -v -sW 192.168.0.67

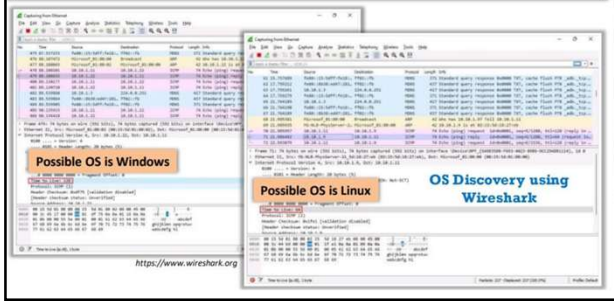
Starting nmap 3.81 ( http://www.insecure.org/nmap/ ) at 2005-04-24 11:37 EDT
Initiating Window Scan against 192.168.0.67 [1663 ports] at 11:37
Discovered open port 23/tcp on 192.168.0.67
Discovered open port 21/tcp on 192.168.0.67
Discovered open port 111/tcp on 192.168.0.67
The Window Scan took 1.91s to scan 1663 total ports.
Host 192.168.0.67 appears to be up ... good.
Interesting ports on 192.168.0.67:
(The 1660 ports scanned but not shown below are in state: closed)
PORT    STATE SERVICE
21/tcp  open  ftp
23/tcp  open  telnet
111/tcp open  rpcbind
MAC Address: 00:10:A4:07:61:30 (Xircom)

Nmap finished: 1 IP address (1 host up) scanned in 2.749 seconds
               Raw packets sent: 1710 (68.4KB) | Rcvd: 1664 (76.5KB)
#
```

32

How to Identify Target System OS

- Attackers can identify the OS running on the target machine by looking at the **Time To Live (TTL)** and **TCP window size** in the IP header of the first packet in a TCP session
- **Sniff/capture the response** generated from the target machine using packet-sniffing tools like Wireshark and observe the TTL and TCP window size fields



Window size values for OS

Operating System	Time To Live	TCP Window Size
Linux	64	5840
FreeBSD	64	65535
OpenBSD	255	16384
Windows	128	65,535 bytes to 1 Gigabyte
Cisco Routers	255	4128
Solaris	255	8760
AIX	255	16384

33

Attaque par balayage FIN, Xmas Tree, et Null

nmap -sF; -sX; -sN

- Ces trois types de scan exploitent une subtile faille de la RFC TCP pour différencier les ports entre ouverts et fermés.
  - "si le port [de destination] est dans **l'état fermé**... un segment ne contenant pas le drapeau RST provoque l'émission d'**un paquet RST comme réponse**.".
  - Pour les **paquets envoyés** à des ports **sans aucun des drapeaux SYN, RST ou ACK activés** (**balayage Null**): "il est peu vraisemblable que cela arrive, mais si cela est le cas, **il faut rejeter le segment.**"

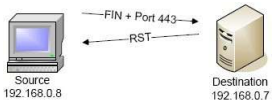
34

Attaque par balayage FIN, Xmas Tree, et Null

nmap -sF; -sX; -sN

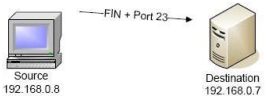
Scan FIN (-sF): N'active que le bit FIN.

- Si **le port est fermé**, il répond par un **RST**




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8] [192.168.0.7] TCP: D=443 S=62178 FIN SEQ=3532094343 LEN=0 WIN=2048
[192.168.0.7] [192.168.0.8] TCP: D=62178 S=443 RST ACK=3532094343 WIN=0
```

- Si **le port est ouvert**, Aucune réponse n'est envoyée




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8] [192.168.0.7] TCP: D=23 S=62178 FIN SEQ=3532094343 LEN=0 WIN=2048
```

35

Attaque par balayage FIN, Xmas Tree, et Null

nmap –sF

```
# nmap -sF -v 192.168.0.7

Starting nmap 3.81 ( http://www.insecure.org/nmap/ ) at 2005-04-23 21:17 EDT
Initiating FIN Scan against 192.168.0.7 [1663 ports] at 21:17
The FIN Scan took 1.51s to scan 1663 total ports.
Host 192.168.0.7 appears to be up ... good.
Interesting ports on 192.168.0.7:
(The 1654 ports scanned but not shown below are in state: closed)
PORT     STATE         SERVICE
21/tcp   open|filtered ftp
22/tcp   open|filtered ssh
23/tcp   open|filtered telnet
79/tcp   open|filtered finger
110/tcp  open|filtered pop3
111/tcp  open|filtered rpcbind
514/tcp  open|filtered shell
886/tcp  open|filtered unknown
2049/tcp open|filtered nfs
MAC Address: 00:03:47:6D:28:D7 (Intel)

Nmap finished: 1 IP address (1 host up) scanned in 2.276 seconds
               Raw packets sent: 1674 (66.9KB) | Rcvd: 1655 (76.1KB)
#
```

29

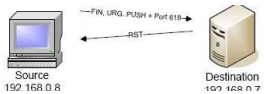
36

Attaque par balayage FIN, Xmas Tree, et Null

nmap -sF; -sX; -sN

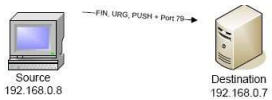
Xmas Tree Scan (-sX): Active les drapeaux FIN, PSH et URG.

- Si **le port est fermé**, il répond par un **RST**




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8]  [192.168.0.7]  TCP: D=618 S=36793 FIN URG PUSH SEQ=3378228596 LEN=0 WIN=1024
[192.168.0.7]  [192.168.0.8]  TCP: D=36793 S=618 RST ACK=3378228596 WIN=0
```

- Si **le port est ouvert**, Aucune réponse n'est envoyée




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8]  [192.168.0.7]  TCP: D=79 S=36793 FIN URG PUSH SEQ=3378228596 LEN=0 WIN=2048
```


37

Attaque par balayage FIN, Xmas Tree, et Null

nmap -sX

```
# nmap -sX -v 192.168.0.7

Starting nmap 3.81 ( http://www.insecure.org/nmap/ ) at 2005-04-23 21:18 EDT
Initiating XMAS Scan against 192.168.0.7 [1663 ports] at 21:18
The XMAS Scan took 1.55s to scan 1663 total ports.
Host 192.168.0.7 appears to be up ... good.
Interesting ports on 192.168.0.7:
(The 1654 ports scanned but not shown below are in state: closed)
PORT     STATE         SERVICE
21/tcp   open|filtered ftp
22/tcp   open|filtered ssh
23/tcp   open|filtered telnet
79/tcp   open|filtered finger
110/tcp  open|filtered pop3
111/tcp  open|filtered rpcbind
514/tcp  open|filtered shell
886/tcp  open|filtered unknown
2049/tcp open|filtered nfs
MAC Address: 00:03:47:6D:28:D7 (Intel)

Nmap finished: 1 IP address (1 host up) scanned in 2.432 seconds
               Raw packets sent: 1674 (66.9KB) | Rcvd: 1655 (76.1KB)
#
```

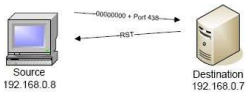

38

Attaque par balayage FIN, Xmas Tree, et Null

nmap -sF; -sX; -sN

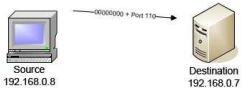
Null can (-sN): N'active aucun des bits (les drapeaux de l'en-tête TCP vallent 0).

- Si **le port est fermé**, il répond par un **RST**




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8]  [192.168.0.7]  TCP: D=438 S=36860      WIN=4096
[192.168.0.7]  [192.168.0.8]  TCP: D=36860 S=438 RST ACK=2138565682 WIN=0
```

- Si **le port est ouvert**, Aucune réponse n'est envoyée




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8]  [192.168.0.7]  TCP: D=110 S=36860      WIN=1024
```

39

Attaque par balayage FIN, Xmas Tree, et Null

nmap -sN

```
# nmap -sN -v 192.168.0.7

Starting nmap 3.81 ( http://www.insecure.org/nmap/ ) at 2005-04-23 21:19 EDT
Initiating NULL Scan against 192.168.0.7 [1663 ports] at 21:19
The NULL Scan took 1.42s to scan 1663 total ports.
Host 192.168.0.7 appears to be up ... good.
Interesting ports on 192.168.0.7:
(The 1654 ports scanned but not shown below are in state: closed)
PORT     STATE         SERVICE
21/tcp   open|filtered ftp
22/tcp   open|filtered ssh
23/tcp   open|filtered telnet
79/tcp   open|filtered finger
110/tcp  open|filtered pop3
111/tcp  open|filtered rpcbind
514/tcp  open|filtered shell
886/tcp  open|filtered unknown
2049/tcp open|filtered nfs
MAC Address: 00:03:47:6D:28:D7 (Intel)

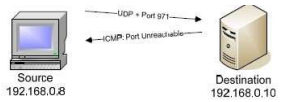
Nmap finished: 1 IP address (1 host up) scanned in 2.251 seconds
               Raw packets sent: 1674 (66.9KB) | Rcvd: 1655 (76.1KB)
#
```

40

Attaque par balayage UDP

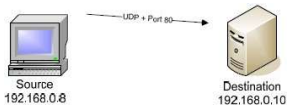
UDP Scan (-sU)

- Pour le protocole UDP:
  - Si **le port est fermé**, un **message ICMP** de type 3 (***destinataire inaccessible***) et code 3 est envoyé




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8]   [192.168.0.10] UDP: D=971 S=43347 LEN=8
[192.168.0.10] [192.168.0.8]   ICMP: Destination unreachable (Port unreachable)
```

  - Si **le port est ouvert|filtré**, **aucune réponse n'est envoyée**.



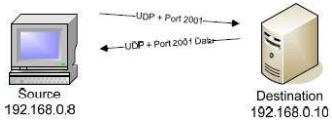

```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8] [192.168.0.10] UDP: D=80 S=43347 LEN=8
```

41

Attaque par balayage UDP

UDP Scan (-sU)

- Si **le port est ouvert**, une réponse avec des données UDP est reçue.




```
Source          Destination     Summary
-------------------------------------------------------------------------------
[192.168.0.8]   [192.168.0.10] UDP: D=2001 S=43347 LEN=8
[192.168.0.10] [192.168.0.8]   UDP: D=43347 S=2001 LEN=40
```

42

Attaque par balayage UDP

UDP Scan (-sU)

```
# nmap -sU -v 192.168.0.10

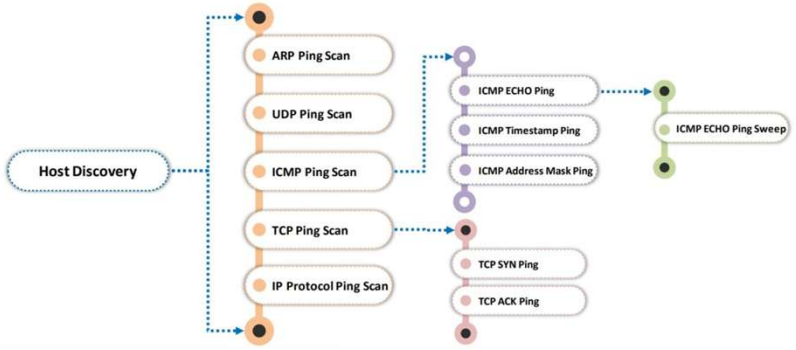
Starting nmap 3.81 ( http://www.insecure.org/nmap/ ) at 2005-04-11 12:44 EDT
Initiating UDP Scan against 192.168.0.10 [1478 ports] at 12:44
Discovered open port 2001/udp on 192.168.0.10
The UDP Scan took 1.47s to scan 1478 total ports.
Host 192.168.0.10 appears to be up ... good.
Interesting ports on 192.168.0.10:
(The 1468 ports scanned but not shown below are in state: closed)
PORT     STATE         SERVICE
123/udp  open|filtered ntp
137/udp  open|filtered netbios-ns
138/udp  open|filtered netbios-dgm
445/udp  open|filtered microsoft-ds
500/udp  open|filtered isakmp
1031/udp open|filtered iad2
1032/udp open|filtered iad3
1900/udp open|filtered UPnP
2001/udp open          wizard
4500/udp open|filtered sae-urn
MAC Address: 00:30:48:11:AB:5A (Supermicro Computer)

Nmap finished: 1 IP address (1 host up) scanned in 2.241 seconds
               Raw packets sent: 1489 (41.7KB) | Rcvd: 1470 (82.3KB)
#
```

43

Host Discovery Techniques

- Host discovery techniques are used to **identify the active/live systems** in the network



44

OS Discovery/Banner Grabbing

- Banner grabbing or OS fingerprinting is the method used to **determine the operating system running on a remote target system**. There are two types of banner grabbing: active and passive
- Identifying the OS used on the target host allows an attacker to **figure out the vulnerabilities possessed by the system** and the exploits that might work on a system to further **carry out additional attacks**

Active Banner Grabbing

- **Specially crafted packets** are sent to the remote OS and the responses are noted
- The responses are then compared with a database to **determine the OS**
- Responses from different OSes vary due to differences in the **TCP/IP stack implementation**



Passive Banner Grabbing

- **Banner grabbing from error messages**

  Error messages provide information such as the type of server, type of OS, and SSL tool used by the target remote system.
- **Sniffing the network traffic**

  Capturing and analyzing packets from the target enables an attacker to determine the OS used by the remote system.
- **Banner grabbing from page extensions**

  Looking for an extension in the URL may assist in determining the application's version.

  Example: .aspx => IIS server and Windows platform

45

Host Discovery Techniques (Cont'd)



Scanning Technique	Nmap Command	Request	Response	Advantages
ARP Ping Scan	nmap -sn -PR <Target IP Address>	ARP request probe	✓ ARP response - Host is active ✓ No response - Host is inactive	✓ More efficient and accurate than other host discovery techniques ✓ Useful for system discovery, where one may need to scan large address spaces
UDP Ping Scan	nmap -sn -PU <Target IP Address>	UDP request	✓ UDP response - Host is active ✓ Error messages (host/network unreachable or TTL exceeded) - Host is inactive	✓ Detects systems behind firewalls with strict TCP filtering
ICMP ECHO Ping Scan	nmap -sn -PE <Target IP Address>	ICMP ECHO request	✓ ICMP ECHO reply - Host is active ✓ No response - Host is inactive	✓ Useful for locating active devices or determining if the ICMP message passes through a firewall **Disadvantage:** ✓ Does not work on Windows-based networks

46

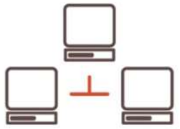
Host Discovery Techniques (Cont'd)

Scanning Technique	Nmap Command	Request	Response	Advantages
ICMP ECHO Ping Sweep	nmap -sn -PE <Target IP Address Range>	ICMP ECHO requests to multiple hosts	✓ ICMP ECHO reply - Host is active ✓ No response - Host is inactive	✓ Determines the live hosts from a range of IP addresses ✓ Useful for creating an inventory of live systems in the subnet **Disadvantage:** ✓ Oldest and slowest method used to scan a network
ICMP Timestamp Ping Scan	nmap –sn –PP <Target IP Address>	ICMP timestamp request	✓ Timestamp reply to each timestamp request ✓ Response from the destination host is conditional, and it may or may not respond with the time value depending on its configuration by the administrator at the target's end	✓ Alternative for the conventional ICMP ECHO ping scan ✓ Determines whether the target host is live, specifically when the administrators block ICMP ECHO pings
ICMP Address Mask Ping Scan	nmap –sn –PM <Target IP Address>	ICMP address mask request	✓ Address mask response from the destination host is conditional, and it may or may not respond with the appropriate subnet value depending on its configuration by the administrator at the target's end	✓ Alternative for the conventional ICMP ECHO ping scan ✓ Determines whether the target host is live, specifically when the administrators block ICMP ECHO pings
TCP SYN Ping Scan	nmap –sn –PS <Target IP Address>	Empty TCP SYN request	✓ ACK response - Host is active ✓ No response - Host is inactive	✓ Used to determine if the host is active without creating any connection ✓ Logs are not recorded at the system or network level, enabling the attacker to leave no traces for detection

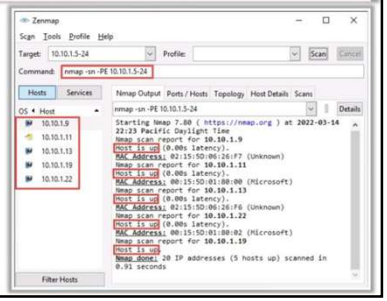
47

Host Discovery Techniques (Cont'd)

Scanning Technique	Nmap Command	Request	Response	Advantages
TCP ACK Ping Scan	nmap –sn –PA <Target IP Address>	Empty TCP ACK request	✓ RST response - Host is active ✓ No response - Host is inactive	✓ Maximizes the chances of bypassing the firewall
IP Protocol Ping Scan	nmap –sn –PO <Target IP Address>	IP ping requests using different IP protocols (ICMP, IGMP, TCP, and UDP)	✓ Any response - Host is active ✓ No response - Host is inactive	✓ Sends different packets using different IP protocols in the hope of receiving a response indicating that a host is online



ICMP ECHO Ping Sweep



48

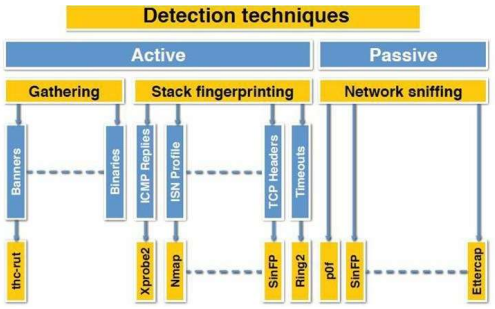
Prise d'empreinte d'un OS

OS Fingerprinting

- Définition: L'OS Fingerprinting est **l'art d'identifier le type et la version du système d'exploitation de l'hôte distant**.
- Il constitue une étape cruciale dans un test d'intrusion.
- On distingue deux catégories de techniques de l'OS Fingerprinting :
  - **Techniques actives** : consistent en l'envoi de paquets sur le réseau et l'attente de réponses. Les paquets envoyés sont parfois malformées car les différentes implémentations des piles TCP/IP répondent différemment face à de telles erreurs.
  - **Techniques passives** : ces méthodes se caractérisent par le fait qu'elles se basent sur l'écoute du trafic réseau sans avoir à envoyer aucun paquet.

49

Techniques d'OS Fingerprinting



50

TCP/IP Stack Fingerprinting

- TCP/IP Stack Fingerprinting est une technique permettant de déterminer l'identité du système d'exploitation utilisé sur une machine distante en analysant les paquets IP provenant de cet hôte.
- **Cette méthode se base sur le fait que les différents systèmes n'implémentent pas de la même manière les protocoles réseaux TCP et IP.**
- La plupart des systèmes d'exploitation répondent différemment si des paquets anormaux ou bizarres leur sont envoyés.

51

Technique de nmap pour la prise d'empreintes d'OS

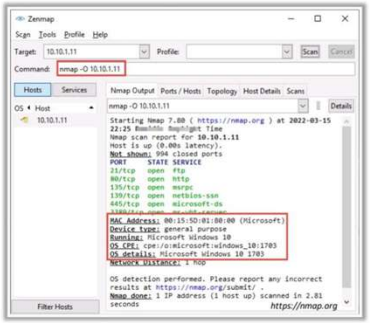
- Nmap inclut une méthode de détection d'OS basée sur la réponse de la machine cible à une série de 9 tests :
  - 1 test sur un port UDP fermé qui renvoie un message d'erreur ICMP.
  - 1 test permettant à partir d'un échantillon de paquets TCP de faire des analyses statistiques sur la génération des IP ID et des TCP sequence number.
  - 4 tests sur des ports TCP ouverts.
  - 3 tests sur des ports TCP fermés.
- Ces neuf tests permettent de créer une empreinte du système d'exploitation de la machine en notant la valeur de champs intéressants dans les paquets TCP/IP.

40

52

OS Discovery using Nmap and Unicornscan

- In **Nmap**, the **-O** option is used to perform OS discovery, providing OS details of the target machine
- In **Unicornscan**, the OS of the target machine can be identified by **observing the TTL values** in the acquired scan result





53

Technique de nmap pour la prise d'empreintes d'OS

Test	Envoyer paque	à un Port	avec les Flags
T1	TCP	TCP-ouvert	SYN, ECN-ECHO
T2	TCP	TCP-ouvert	no flags
T3	TCP	TCP-ouvert	URG, PSH, SYN, FIN
T4	TCP	TCP-ouvert	ACK
T5	TCP	TCP-fermé	SYN
T6	TCP	TCP-fermé	ACK
T7	TCP	TCP-fermé	URG, PSH, FIN
T8	UDP	TCP-fermé	
T9	TCP*6	TCP-ouvert	SYN

41

54

Exemple de prise d'empreinte par Nmap

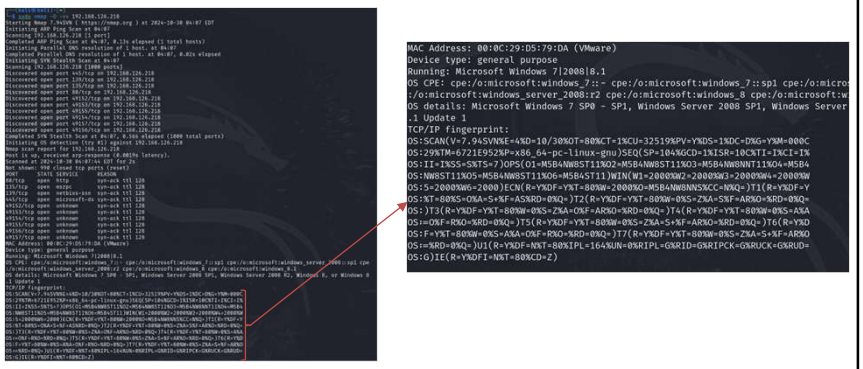
Exemple d'empreinte associée par Nmap à l'OS (fichier nmap-os-fingerprints) :

- Fingerprint Linux 2.6.0 (X86)

```
TSeq(Class=RI%gcd=<6%SI=<269E81A&>62D97%IPID=Z%TS=1000HZ)
T1(DF=Y%W=7FFF%ACK=S++%Flags=AS%Ops=MNNTNW)
T2(Resp=N)
T3(Resp=Y%DF=Y%W=7FFF%ACK=S++%Flags=AS%Ops=MNNTNW)
T4(DF=Y%W=0%ACK=O%Flags=R%Ops=)
T5(DF=Y%W=0%ACK=S++%Flags=AR%Ops=)
T6(DF=Y%W=0%ACK=O%Flags=R%Ops=)
T7(DF=Y%W=0%ACK=S++%Flags=AR%Ops=)
PU(DF=N%TOS=D0%IPLEN=164%RIPTL=148%RID=E%RIPCK=E%UCK=E%ULEN=134
%DAT=E)
```

42

55



56

•SCAN(V=7.94SVN%E=4%D=10/30%OT=80%CT=1%CU=32519%PV=Y%DS=1%DC=D%G=Y%M=000C29%TM=6721E952%P=x86_64-pc-linux-gnu)

- Version de Nmap utilisée (7.94 SVN), date et heure du scan.
- **OT=80** indique que le scan a détecté un port ouvert sur le port 80 (HTTP).
- **CT=1** indique qu'il y a un port fermé détecté (probablement pour le test de détection d'OS).
- **P=x86_64-pc-linux-gnu** signifie que le scan a été lancé depuis une machine exécutant un système Linux 64 bits.

•SEQ, OPS, WIN, ECN, T1 à T7, U1, IE :

- **SEQ** : Tests de séquence pour vérifier le comportement de la génération de numéros de séquence TCP.
- **OPS** : Options TCP envoyées dans la réponse pour vérifier si des options spécifiques sont supportées.
- **WIN** : Taille de la fenêtre TCP pour déterminer les différences entre les ports ouverts et fermés.
- **ECN** : Tests d'options de contrôle d'encombrement explicite.
- **T1 à T7** : Tests de comportement en réponse à divers paquets avec des flags différents.
- **U1** : Test de port UDP pour détecter le comportement en réponse aux paquets UDP.
- **IE** : Test de détection ICMP Echo, montrant comment la cible répond aux requêtes ICMP.